

UNIVERSITAS AL-KHAIRAAT (UAY) • BIRO TEKNOLOGI INFORMASI / PUSTIK

DOKUMEN TINJAUAN TEKNIS & USULAN PENYELARASAN ARSITEKTUR INTEGRASI AUTHENTIKASI & OTORISASI SSO UAY DENGAN E-LEARNING UAY

Kajian Komparatif Bab 7 Dokumen Teknis SSO UAY terhadap Kebutuhan Operasional LMS UAY

Versi: 1.0 | Tanggal: 25 September 2026 | Penyusun: Tim Pengembang E-Learning UAY

1. Ringkasan Eksekutif & Latar Belakang

Dokumen ini disusun sebagai tindak lanjut resmi atas penyerahan Dokumen Teknis SSO UAY oleh Tim Pengembang SSO Universitas Al-Khairaat (UAY) kepada Tim Pengembang E-Learning UAY, dengan rujukan khusus pada Bab 7 (Authentication & Session).

Tim Pengembang E-Learning telah melakukan audit komparatif mendalam terhadap Bab 7 (sub-bab 7.1 hingga 7.15) dan merumuskan kesimpulan strategis sebagai berikut:

- **Fondasi Protokol Modern:** Penerapan OpenID Connect (OIDC) dan OAuth 2.0 menggunakan Authorization Code Flow dengan PKCE (RFC 7636) pada Keycloak telah memenuhi standar baku keamanan industri pendidikan tinggi.
- **Arsitektur Dua Lapis (Two-Tier Architecture):** Bab 7.7 mendefinisikan pemisahan di mana Lapis 1 (Keycloak) menangani Autentikasi Pengguna, dan Lapis 2 (SSO Backend) mengelola Otorisasi Terpusat melalui tabel `application_access` dan `roles`.
- **Kesenjangan Kritis (Critical Gap):** Sesuai spesifikasi klaim token Keycloak pada Bab 7.5, token JWT yang diterbitkan saat ini HANYA memuat identitas dasar (`sub`, `preferred_username`, `email`, `name`). Token tersebut BELUM memuat: (1) Nomor identitas akademik mahasiswa/dosen (`identifier_value` seperti NIM/NIDN), (2) Hak akses atau peran spesifik aplikasi (`roles`), dan (3) Penegasan status keaktifan akun (`account_status`: `ACTIVE`).
- **Implikasi Operasional:** Tanpa data identitas akademik dan peran aplikasi, sistem E-Learning tidak dapat mengaitkan pengguna dengan rombongan belajar (kelas), kurikulum program studi, penilaian tugas/kuis, serta tidak dapat menjalankan kontrol akses berbasis peran (RBAC).

TUJUAN PENGAJUAN USULAN

Untuk menjembatani kesenjangan ini tanpa menimbulkan hambatan teknis atau saling tunggu antar tim, dokumen ini menyajikan dua opsi solusi arsitektur: Opsi 1 (Penyesuaian di sisi SSO via Keycloak Protocol Mappers) dan Opsi 2 (Penyesuaian di sisi E-Learning via SSO Backend API). Tim E-Learning siap mengimplementasikan salah satu dari kedua opsi tersebut.

2. Matriks Evaluasi Butir per Butir Bab 7 Dokumen Teknis SSO UAY

Tabel berikut menyajikan telaah teknis mendalam terhadap 15 butir pada Bab 7 Dokumen Teknis SSO UAY dibandingkan dengan kesiapan dan kebutuhan operasional sistem E-Learning UAY:

Sub - Bab	Spesifikasi SSO UAY	Kebutuhan E-Learning	Status	Tindak Lanjut Teknis
7.1	Standar Protokol: OIDC & OAuth 2.0, Authorization Code + PKCE (RFC 7636).	E-Learning telah mengimplementasikan PKCE dengan <code>code_challenge_method=S256</code> .	Sesuai Penuh	Pertahankan konfigurasi client elearning-uay dengan PKCE wajib.
7.2	Alur Autentikasi: Login terpusat via Keycloak Login Page.	Pengguna dialihkan ke Keycloak; E-Learning menerima <code>authorization_code</code> .	Sesuai Penuh	Daftarkan redirect URI resmi: <code>/api/v1/auth/callback</code> .
7.3	Single Sign-On Behavior: Keycloak SSO Session Cookie.	Pengguna yang login di Portal UAY langsung terautentikasi saat membuka LMS.	Sesuai Penuh	Didukung otomatis oleh Keycloak SSO Session.
7.4	Single Sign-Out: RP-Initiated Logout via Keycloak <code>end_session_endpoint</code> .	Logout di LMS membersihkan sesi lokal dan memanggil <code>end_session_endpoint</code> .	Sesuai Penuh	E-Learning menyertakan <code>id_token_hint</code> dan <code>post_logout_redirect_uri</code> .
7.5	Struktur & Klaim Token: <code>sub</code> , <code>preferred_username</code> , <code>email</code> , <code>name</code> , <code>iss</code> , <code>aud</code> , <code>exp</code> .	Kritis: Token tidak memiliki <code>roles</code> , <code>identifier_value</code> (NIM/NIDN), dan <code>account_status</code> .	Kesenjangan Kritis	Memerlukan Opsi 1 (Protocol Mapper) atau Opsi 2 (Query API SSO Backend).
7.6	Validasi Token: Verifikasi asimetris via JWKS URI, RS256/ES256, caching key.	E-Learning memverifikasi signature token secara lokal via jose & JWKS remote cache.	Sesuai Penuh	Tidak ada perubahan pada logika kriptografi verifikasi token.
7.7	Arsitektur Otorisasi Dua Lapis: Lapis 1 = Keycloak, Lapis 2 = SSO Backend.	E-Learning siap mengadopsi Lapis 2 jika API SSO Backend tersedia resmi.	Titik Temu	Dijadikan landasan perancangan solusi Opsi 2.
7.8	Skema Data Otorisasi: <code>application_access</code> , <code>roles</code> , <code>permissions</code> , dsb.	Struktur database SSO Backend sangat lengkap dan selaras dengan LMS.	Sesuai Struktur	Kolom <code>roles.name</code> menjadi sumber otoritas hak akses di LMS.
7.9	Alur Evaluasi Akses: Klien memanggil SSO Backend API untuk Auth Context.	Alur query SQL dijelaskan, namun belum ada kontrak REST API resmi.	Perlu Kontrak API	Memerlukan penerbitan kontrak endpoint resmi dari Tim SSO.
7.10	Refresh Token: Penukaran token refresh ke Keycloak token endpoint.	Backend E-Learning mengelola rotasi token dan menyimpan di HttpOnly cookie.	Sesuai Penuh	Sesuai spesifikasi standar RFC 6749.
7.11	Manajemen Masa Berlaku Token: Access token 15 menit, refresh token 8 jam.	Kode E-Learning memvalidasi umur token: <code>payload.exp - payload.iat <= 900</code> .	Sesuai Penuh	Konfigurasi waktu kedaluwarsa sudah identik (15 menit).
7.12	Penanganan Token Kedaluwarsa: Silent refresh dan deteksi reuse.	Middleware LMS mendeteksi token kedaluwarsa dan memicu refresh di background.	Sesuai Penuh	Mekanisme rotasi token berjalan transparan bagi pengguna.
7.13	Penyimpanan Kredensial: Cookie HttpOnly, Secure, SameSite=Lax.	E-Learning menolak penyimpanan di localStorage demi mencegah XSS.	Sesuai Penuh	Standar keamanan penyimpanan token telah terpenuhi.

Sub - Bab	Spesifikasi SSO UAY	Kebutuhan E-Learning	Status	Tindak Lanjut Teknis
7.14	Pencegahan Replay & CSRF: Parameter state, nonce, PKCE code_verifier.	E-Learning memverifikasi integritas state sebelum menukar token.	Sesuai Penuh	Memitigasi serangan CSRF dan Replay secara tuntas.
7.15	Penonaktifan Pengguna: Pencabutan akses jika akun dinonaktifkan.	LMS memiliki cache blacklist lokal, butuh propagasi instan dari SSO.	Perlu Penyelarasan	Diselaraskan via Webhook Revocation atau TTL token 15 menit.

3. Analisis Mendalam 5 Kesenjangan Kritis & Implikasi Teknis

3.1 Ketiadaan Identitas Akademik Mahasiswa & Dosen (NIM / NIDN)

Bab 7.5 menetapkan bahwa Keycloak hanya menyertakan klaim profil umum (sub, preferred_username, email, name). Di perguruan tinggi, sub (UUID) dan username tidak cukup untuk menghubungkan mahasiswa ke rombongan belajar (kelas kuliah), kurikulum prodi, presensi, pengisian nilai di SIMAK/SIKAD, serta sinkronisasi KRS. E-Learning secara mutlak memerlukan NIM untuk mahasiswa dan NIDN/NIP untuk dosen.

Implikasi Operasional: Jika atribut ini tidak tersedia saat login, E-Learning tidak dapat melakukan Just-In-Time (JIT) provisioning akun akademik, sehingga mahasiswa yang berhasil login tidak akan menemukan mata kuliah yang diikutinya.

3.2 Ketiadaan Hak Akses & Peran Aplikasi (roles)

Token Keycloak saat ini tidak memuat informasi peran spesifik aplikasi E-Learning. E-Learning menerapkan Role-Based Access Control (RBAC) yang ketat untuk membedakan antara STUDENT, INSTRUCTOR, DEPARTMENT_ADMIN, dan SUPER_ADMIN.

Implikasi Operasional: Sesuai apps/api/src/auth.ts dan packages/shared/src/sso.ts, ketiadaan peran menyebabkan penolakan akses (403 Forbidden) dengan galat 'No E-Learning role granted for this account'.

3.3 Ketiadaan Validasi Status Akun Pengguna (account_status: ACTIVE)

Kode otorisasi E-Learning mewajibkan adanya penegasan bahwa status akun pengguna adalah ACTIVE (payload.account_status === 'ACTIVE'). Hal ini penting untuk mencegah mahasiswa cuti, non-aktif, atau terkena sanksi akademik mengakses materi pembelajaran dan ujian daring.

Implikasi Operasional: Token Keycloak standar saat ini langsung ditolak oleh middleware LMS dengan galat 'ACCOUNT_DISABLED' karena properti account_status bernilai undefined.

3.4 Penyelarasan Taksonomi Peran (Role Mapping)

Dokumen SSO menggunakan label deskriptif berbahasa Indonesia seperti 'DOSEN' dan 'MAHASISWA', sedangkan domain model E-Learning menggunakan konvensi enum arsitektur bersih: INSTRUCTOR, STUDENT, DEPARTMENT_ADMIN, dan SUPER_ADMIN. Diperlukan penetapan mapping resmi agar tidak terjadi kegagalan type casting saat sinkronisasi identitas.

3.5 Spesifikasi & Kepastian Kontrak Endpoint Otorisasi SSO Backend

Bab 7.9 memaparkan alur evaluasi akses secara konseptual melalui query SQL ke tabel `application_access`, namun belum mendokumentasikan spesifikasi REST API (URL endpoint, metode HTTP, header otentikasi, format payload JSON respon, dan penanganan galat). Kepastian kontrak ini mutlak diperlukan jika Opsi 2 dipilih.

4. Opsi Usulan 1: Penyesuaian Sisi SSO (Token Enrichment via Keycloak)

Pada Opsi 1, Tim SSO mengonfigurasi Protocol Mappers khusus pada client `elearning-uay` di Keycloak. Dengan konfigurasi ini, Keycloak menyematkan data identitas akademik, peran aplikasi, dan status akun langsung ke dalam token JWT yang diterbitkan.

ARSITEKTUR ALUR KERJA OPSI 1 (STATELESS / ZERO LATENCY)

Pengguna Login di Keycloak -> Keycloak membaca database SSO -> Keycloak menerbitkan Token JWT berisi [NIM/NIDN, roles, account_status] -> Pengguna mengirim token ke E-Learning -> Backend E-Learning memvalidasi token secara lokal via JWKS (0 ms latensi jaringan ke SSO Backend).

Langkah-Langkah Konfigurasi Teknis di Admin Console Keycloak:

1. Mapper 1 (`user_type`): Buat User Attribute Mapper, Name: `user_type_mapper`, User Attribute: `user_type`, Token Claim Name: `user_type`, Claim JSON Type: String, Add to ID/Access Token: ON.
2. Mapper 2 (`account_status`): Buat User Attribute Mapper, Name: `account_status_mapper`, User Attribute: `status`, Token Claim Name: `account_status`, Claim JSON Type: String (nilai: `ACTIVE`), Add to ID/Access Token: ON.
3. Mapper 3 (`identifier_value` & `identifier_type`): Buat User Attribute Mapper untuk memetakan NIM/NIDN ke klaim `identifier_value` dan tipe ke `identifier_type`.
4. Mapper 4 (`roles`): Buat User Client Role Mapper atau Attribute Mapper, Name: `elearning_roles_mapper`, Token Claim Name: `roles`, Claim JSON Type: JSON (Array of Strings), Add to ID/Access Token: ON, Multivalued: ON.

Contoh Payload Token JWT yang Diharapkan (Self-Contained Token):

```
{
  "exp": 1741500000,
  "iat": 1741499100,
  "jti": "b3c8f2a1-5d4e-4f8a-9c2b-1a2b3c4d5e6f",
  "iss": "https://sso.uay.ac.id/realms/uay",
  "aud": "elearning-uay",
  "sub": "a1b2c3d4-e5f6-7890-abcd-ef1234567890",
  "preferred_username": "202401001",
  "email": "ahmad.dahlan@uay.ac.id",
  "name": "Ahmad Dahlan",
  "user_type": "STUDENT",
  "account_status": "ACTIVE",
  "identifier_type": "NIM",
  "identifier_value": "202401001",
  "roles": ["STUDENT"],
  "department_scopes": ["INFORMATIKA"]
}
```

Kelebihan Opsi 1: Latensi 0 ms (tanpa network hop tambahan), stateless & tahan lonjakan trafik ujian serentak, serta zero code modification di sisi E-Learning.

Batasan: Memerlukan konfigurasi protocol mapper di Keycloak Admin Console oleh Tim SSO (estimasi pengerjaan: 30–60 menit).

5. Opsi Usulan 2: Penyesuaian Sisi E-Learning (Two-Tier Decoupled Architecture)

Pada Opsi 2, Tim SSO tidak perlu mengubah konfigurasi Keycloak. E-Learning beradaptasi sepenuhnya dengan arsitektur Bab 7.7–7.9: Keycloak hanya bertugas melakukan autentikasi identitas, sedangkan E-Learning menambahkan adapter HTTP internal untuk memanggil REST API SSO Backend guna mengambil Konteks Otorisasi dan data akademik.

ARSITEKTUR ALUR KERJA OPSI 2 (TWO-TIER ADAPTER)

Pengguna Login di Keycloak -> E-Learning menerima Token dasar (Bab 7.5) -> Backend E-Learning memvalidasi JWKS -> Backend E-Learning memanggil GET /api/v1/auth/context ke SSO Backend -> SSO Backend mengeksekusi query database Bab 7.8 -> E-Learning menyimpan Konteks Otorisasi di Redis/Memory Cache selama 15 menit.

Spesifikasi Kontrak API SSO Backend yang Dibutuhkan oleh E-Learning:

Endpoint Path: GET /api/v1/auth/context (atau GET /api/v1/users/me/access)

Headers Permintaan: Authorization: Bearer <keycloak_token>, X-Client-ID: elearning-uay, Accept: application/json

Contoh Payload Respon JSON dari SSO Backend (200 OK):

```
{
  "user_id": "a1b2c3d4-e5f6-7890-abcd-ef1234567890",
  "username": "202401001",
  "name": "Ahmad Dahlan",
  "email": "ahmad.dahlan@uay.ac.id",
  "user_type": "STUDENT",
  "status": "ACTIVE",
  "primary_identifier": {
    "type": "NIM",
    "value": "202401001"
  },
  "application_access": {
    "client_id": "elearning-uay",
    "roles": ["STUDENT"],
    "permissions": ["courses.view", "assignments.submit", "quizzes.take"],
    "department_scopes": ["INFORMATIKA"],
    "is_active": true,
    "expires_at": null
  }
}
```

Mekanisme Resiliensi & Caching di E-Learning: Respon API akan di-cache secara lokal selama 15 menit sejalan dengan masa aktif token Keycloak. E-Learning juga menerapkan Circuit Breaker agar sistem tetap dapat beroperasi menggunakan data lokal apabila SSO Backend mengalami gangguan sementara.

Kelebihan Opsi 2: Mematuhi arsitektur Lapis 2 murni rancangan Tim SSO; Tim SSO tidak perlu menyentuh konfigurasi Keycloak.

Batasan: Menambah 1 network hop (latensi 30–120 ms saat login), menimbulkan dependensi runtime ke SSO Backend API, dan membutuhkan penyesuaian kode pada backend E-Learning.

6. Matriks Komparasi Opsi 1 vs Opsi 2

Tabel berikut merangkum perbandingan teknis antara Opsi 1 dan Opsi 2 sebagai bahan pertimbangan bagi pimpinan dan Tim SSO:

Kriteria Evaluasi	Opsi 1: Token Enrichment (Keycloak)	Opsi 2: Two-Tier Adapter (SSO Backend API)	Analisis Dampak
Latensi & Kecepatan	Optimal (0 ms overhead). Validasi token 100% lokal via JWKS cache.	Menengah (+30 s.d. 120 ms) saat login awal atau saat cache miss.	Opsi 1 memberikan performa terbaik saat ujian daring serentak.
Beban Server SSO	Sangat Ringan. Server SSO hanya melayani handshake OIDC awal.	Tinggi. SSO Backend melayani query database untuk setiap sesi login.	Opsi 1 melindungi database SSO dari beban lonjakan query.
Kompleksitas Tim SSO	Sangat Rendah (Konfigurasi Saja). Menambah mapper di Keycloak UI (30-60 menit).	Sedang s.d. Tinggi. Merilis dan memelihara endpoint REST API otorisasi.	Opsi 1 menghemat sumber daya dan waktu pengerjaan Tim SSO.
Kompleksitas Tim LMS	Nol (Zero Code Modification). Kode LMS sudah siap memproses token lengkap.	Sedang. Menambahkan client HTTP ke SSO Backend, caching, & fallback.	Tim E-Learning siap mengembangkan adapter Opsi 2 jika dipilih.
Kepatuhan Standar	Tinggi (Standar OIDC). Token enrichment adalah fitur standar Keycloak.	Pola Hybrid / Proprietary. Bergantung pada API khusus SSO Backend.	Opsi 1 lebih modular dan portable sesuai best practice microservices.
Propagasi Perubahan Role	Menunggu Refresh Token (Maks. 15 menit) atau login ulang.	Mendekati Instan s.d. 15 menit (bergantung pada durasi caching).	Relatif seimbang karena Opsi 2 pun wajib menerapkan caching.
Ketahanan Sistem	Tinggi. LMS tetap aktif memvalidasi token meskipun SSO Backend down.	Rentan. Jika SSO Backend offline, proses login LMS terhambat.	Opsi 1 memiliki isolasi kegagalan (fault tolerance) yang lebih baik.
Estimasi Waktu Go-Live	1–2 Hari Kerja (konfigurasi mapper + testing integrasi).	1–2 Minggu Kerja (finalisasi endpoint API SSO + refactor auth LMS).	Opsi 1 menawarkan jalur integrasi yang jauh lebih cepat.

7. Penyelarasan Taksonomi Peran (Role Mapping Matrix)

Untuk memastikan keselarasan hak akses antara database SSO UAY dan sistem E-Learning UAY, disepakati aturan pemetaan peran sebagai berikut:

Peran pada SSO UAY	Peran pada E-Learning	Hak Akses & Kewenangan di E-Learning UAY
MAHASISWA / STUDENT	STUDENT	Mengakses materi kuliah, mengumpulkan tugas, mengikuti kuis/ujian daring, melihat nilai pribadi, dan berdiskusi di forum kelas.
DOSEN / LECTURER / PENGAJAR	INSTRUCTOR	Mengelola silabus dan modul, mengunggah materi, membuat tugas & bank soal ujian, memberikan penilaian, dan mengelola kelas.
ADMIN_PRODI / STAFF_AKADEMIK	DEPARTMENT_ADMIN	Memantau seluruh mata kuliah dalam program studi, melihat analitik akademik prodi, dan mengelola alokasi dosen pengampu.
SUPER_ADMIN / ADMIN_PUSAT	SUPER_ADMIN	Kendali penuh atas sistem LMS, konfigurasi integrasi SSO, audit log keamanan, dan pemeliharaan lintas fakultas/prodi.

Aturan Multi-Peran: Jika seorang pengguna memiliki lebih dari satu peran di SSO, E-Learning menetapkan peran efektif berdasarkan hierarki tertinggi: SUPER_ADMIN > DEPARTMENT_ADMIN > INSTRUCTOR > STUDENT.

8. Protokol Keamanan, Penonaktifan Akun (Bab 7.15), & Siklus Sesi

8.1 Sinkronisasi Penonaktifan Akun (Bab 7.15)

1. Mekanisme Pasif (Standar OIDC): Dengan masa aktif token 15 menit, penonaktifan akun di Keycloak/SSO akan otomatis menghentikan akses pengguna maksimal dalam 15 menit saat token refresh ditolak oleh Keycloak.
2. Mekanisme Aktif (Webhook Revocation): Tim SSO dapat memanggil webhook internal LMS saat akun dinonaktifkan: POST /api/v1/auth/internal/revoke-user dengan payload {'sso_user_id': 'uuid', 'reason': 'ACCOUNT_DISABLED'} untuk mencabut akses seketika (< 1 detik).

8.2 Single Sign-Out (RP-Initiated Logout — Bab 7.4)

Saat pengguna logout di LMS: (1) LMS membersihkan cookie sesi lokal, (2) Browser dialihkan ke Keycloak end_session_endpoint dengan menyertakan id_token_hint dan post_logout_redirect_uri, (3) Keycloak menghapus sesi terpusat dan mengarahkan kembali ke halaman login LMS.

9. Rekomendasi Tim Pengembang, Action Plan, & Jadwal Integrasi

Rekomendasi Resmi: Berdasarkan pertimbangan performa bebas latensi (0 ms), keandalan saat lonjakan akses ujian massal, efisiensi beban server SSO, dan waktu implementasi tercepat, Tim Pengembang E-Learning merekomendasikan Opsi 1 (Token Enrichment via Keycloak).

Kesiapan Menjalankan Opsi 2: Apabila Tim SSO menetapkan bahwa Keycloak tidak diperbolehkan menyimpan atau memetakan atribut aplikasi, Tim E-Learning 100% siap mengimplementasikan Opsi 2, asalkan endpoint API SSO Backend (Bab 5.2) telah aktif di lingkungan staging.

Tahap	Aktivitas	Pelaksana	Target Waktu
-------	-----------	-----------	--------------

Tahap	Aktivitas	Pelaksana	Target Waktu
Tahap 1	Evaluasi & Pemilihan Opsi (Opsi 1 atau Opsi 2)	Tim SSO & PUSTIK UAY	Hari ke-1
Tahap 2A	Jika Opsi 1: Konfigurasi Protocol Mapper pada Client Keycloak Staging	Tim SSO UAY	Hari ke-2
Tahap 2B	Jika Opsi 2: Penyediaan Endpoint GET /api/v1/auth/context di Staging	Tim SSO UAY	Hari ke-2 s.d. 4
Tahap 3B	Jika Opsi 2: Pembuatan Adapter HTTP SSO Backend di E-Learning	Tim E-Learning UAY	Hari ke-4 s.d. 7
Tahap 4	Pengujian Integrasi Terpadu (End-to-End Integration Testing)	Tim SSO & Tim E-Learning	Hari ke-8
Tahap 5	Migrasi Konfigurasi & Rilis ke Lingkungan Production	Tim SSO & Tim E-Learning	Hari ke-9

10. Lembar Pengesahan & Konfirmasi Kesepakatan (Sign-Off Sheet)

Dokumen ini disusun untuk mempercepat terwujudnya integrasi Single Sign-On yang aman, andal, dan berstandar tinggi demi kemajuan ekosistem teknologi informasi di lingkungan Universitas Al-Khairaat.

Palu, 25 September 2026

Perwakilan Tim Pengembang E-Learning UAY	Perwakilan Tim Pengembang SSO UAY	Mengetahui, Kepala Biro TI / PUSTIK UAY
(_____) Lead Engineer LMS	(_____) Lead Engineer SSO	(_____) Kepala PUSTIK UAY